Daftar Isi

Paket Latihan Phishing Internal — Villa Agency OS

0. Ringkasan 30 detik
1. Batas yang tidak boleh dilewati
2. Prasyarat teknis (periksa dulu, jangan lewati)
3. Jangkar anti-phishing: ciri pesan asli villa
4. Tiga simulasi
    4.1 booking_palsu — "tamu minta refund ke rekening lain"
    4.2 payment_failed — "kartu ditolak, klik untuk memperbarui"
    4.3 invoice_vendor — "tagihan vendor, lampiran .html"
5. Infrastruktur minimal (atau nol infrastruktur)
6. Jadwal 6 minggu
7. Ambang & putusan
8. Checklist hari-H
9. Pasca-latihan
10. Format CSV
11. Menjalankan skrip
12. Yang belum dicakup (jujur)
13. Sisi tamu: satu pesan resmi untuk pelapor

Paket Latihan Phishing Internal — Villa Agency OS

Untuk: owner, manager operasional, dan staf yang menerima email/WhatsApp masuk **Status:** siap dijalankan **setelah** persetujuan tertulis owner (§1.5) **Edisi:** 2026-10-25 · **Skrip penilai:** `scripts/phishing_drill_score.py` **Dasar:** `docs/SECURITY_TRIAGE_2026-10.md` prioritas #4 · `docs/MESSAGE_TEMPLATES.md` (pesan resmi)

---

0. Ringkasan 30 detik

Pertanyaan	Jawaban
Siapa yang diuji?	**Staf internal.** Tamu nyata **tidak pernah** menerima simulasi.
Berapa lama?	6 minggu: 2 minggu baseline → 1 sesi latihan → 2 minggu retest → 1 minggu laporan
Berapa email?	3 skenario × 1 email per orang per gelombang
Ukuran keberhasilan	Kredensial terkirim **0**, klik **≤ 10%**, lapor **≥ 50%**, kohort **≥ 5**
Siapa yang melihat nama?	Hanya orangnya + manager langsung. Laporan ke owner **agregat**.
Kalau gagal?	Bukan hukuman — coaching 15 menit, lalu ukur ulang.

Latihan ini mengukur **satu hal**: apakah staf berhenti dan memverifikasi sebelum bertindak. Bukan mengukur kerajinan, bukan loyalitas, bukan kecerdasan.

---

1. Batas yang tidak boleh dilewati

#	Aturan	Alasan
1.1	**Jangan kirim ke tamu nyata**, termasuk tamu yang sedang menginap	Mereka bukan karyawan; tidak ada consent, dan insiden nyata bisa merusak reputasi
1.2	Domain pengirim wajib berakhiran `.invalid` (mis. `latihan@drill.invalid`)	RFC 2606: TLD ini tidak bisa didaftarkan siapa pun, jadi simulasi tidak mungkin berubah jadi phishing sungguhan
1.3	**Jangan meniru bank, OJK, atau instansi pemerintah**	Di luar kewenangan kita, dan bisa masuk ranah pidana
1.4	Form simulasi **tidak boleh** punya kolom kata sandi, kartu, atau KTP; input tidak dikirim ke mana pun	Yang diukur adalah klik, bukan isi. Tidak ada data sensitif yang boleh terbentuk
1.5	**Consent tertulis owner** + pemberitahuan ke manager sebelum gelombang pertama	UU PDP 27/2022: pemantauan perilaku karyawan butuh dasar yang jelas dan proporsional
1.6	**Tanpa mempermalukan**: tidak ada pengumuman "siapa yang klik"	Rasa malu membuat orang menyembunyikan klik berikutnya — metrik jadi palsu
1.7	Data mentah dihapus **90 hari** setelah laporan	Minimalisasi data; yang disimpan hanya agregat
1.8	**Kill switch**: satu perintah/telepon menghentikan kampanye	Kalau ada insiden nyata bersamaan, latihan harus bisa dihentikan seketika

---

2. Prasyarat teknis (periksa dulu, jangan lewati)

Latihan phishing di domain yang belum punya autentikasi email hanya mengukur separuh hal.

Prasyarat	Cara periksa	Syarat lulus
SPF	`dig TXT <domain> +short`	ada record, `-all` atau `~all`
DKIM	header `DKIM-Signature` pada email keluar	ada dan `pass`
DMARC	`dig TXT _dmarc.<domain> +short`	`p=reject` (minimal `quarantine`), ada `rua=`
Header drill	email simulasi diberi `X-Drill: true`	admin bisa membedakan tanpa membuka isi

Bila DMARC masih `p=none`, **perbaiki dulu**: tanpa itu, email palsu atas nama domain villa memang bisa lolos ke tamu, dan latihan staf tidak menutup lubang itu.

---

3. Jangkar anti-phishing: ciri pesan asli villa

Staf tidak perlu hafal teori. Mereka perlu hafal **enam ciri pesan asli** (diturunkan dari `docs/MESSAGE_TEMPLATES.md`, tempat seluruh kalimat resmi dipin):

Ciri	Pesan asli	Tiruan
Nomor rujukan	`booking_ref` / `invoice_ref` **cocok** dengan dashboard	nomor karangan, atau tidak ada
Rekening	hanya rekening **atas nama perusahaan** yang tercetak di invoice	rekening pribadi / "rekening baru"
Data sensitif	**tidak pernah** minta kartu, KTP, atau kata sandi lewat email/chat	meminta "verifikasi kartu"
Kanal	satu nomor WhatsApp bisnis resmi + email domain resmi	nomor baru, `Reply-To` beda domain
Lampiran	PDF invoice dari sistem	`.zip`, `.html`, `.htm`, atau tautan "login"
Tekanan waktu	tidak mengancam dalam hitungan menit	"dalam 2 jam akun ditutup"

Aturan satu kalimat untuk staf: *kalau pesan meminta uang, data, atau klik — berhenti, buka dashboard sendiri, jangan lewat tautan di pesan itu.*

---

4. Tiga simulasi

Setiap simulasi punya satu tujuan pengukuran. Jangan gabungkan dua tujuan dalam satu email.

4.1 booking_palsu — "tamu minta refund ke rekening lain"

Tujuan: mengukur apakah staf memverifikasi perubahan rekening lewat kanal resmi.

```
Subjek: Permintaan pembatalan — {booking_ref}
Dari:    reservations@drill.invalid
Reply-To: refund@drill.invalid

Selamat siang,

Saya {nama} yang memesan unit {unit_code} untuk {check_in}.
Karena ada perubahan rencana, mohon pembatalan diproses hari ini.
Karena kartu saya bermasalah, mohon refund dikirim ke rekening berikut:
Bank {bank} — {nomor} — a.n. {nama}.

Mohon konfirmasi sebelum pukul 17.00 agar dana tidak tertahan.
Terima kasih.
```

Tanda bahaya	Respons benar
Rekening berbeda dari data booking	Buka dashboard, cek `booking_ref` — apakah ada?
`Reply-To` beda domain	Balas **hanya** ke kanal yang tercatat di booking, bukan `Reply-To`
Tenggat "hari ini"	Refund **tidak pernah** diproses dari email; butuh approval di sistem
Nama bank/nomor diformat aneh	Laporkan ke manager + `security@` sebelum menjawab

4.2 payment_failed — "kartu ditolak, klik untuk memperbarui"

Tujuan: mengukur apakah staf mengeklik tautan "login" dari email.

```
Subjek: Pembayaran gagal — pesanan {booking_ref}
Dari:    billing@drill.invalid

Kami tidak dapat memproses pembayaran untuk pesanan {booking_ref}.
Perbarui metode pembayaran dalam 2 jam agar unit tidak dilepas:
https://drill.invalid/perbarui?r={recipient_id}
```

Tanda bahaya	Respons benar
Tautan berisi ID penerima (personal)	Jangan klik; buka dashboard dan cari pesanan sendiri
Ancaman waktu 2 jam	Semua tenggat nyata tercatat di invoice, bukan di email
Tidak ada `invoice_ref`	Pesan resmi selalu membawa rujukan yang bisa dicari
Pengirim bukan domain resmi	Laporkan sebagai phishing (satu klik di klien email)

4.3 invoice_vendor — "tagihan vendor, lampiran .html"

Tujuan: mengukur kepatuhan pada aturan "tidak membuka lampiran aktif".

```
Subjek: Invoice {vendor} — jatuh tempo {due_date}
Dari:    finance@{vendor}.drill.invalid
Lampiran: invoice_{vendor}.html

Mohon periksa tagihan bulan ini. Cetak, tanda tangani, dan kirim balik.
```

Tanda bahaya	Respons benar
Lampiran `.html` / `.htm` / `.zip`	Jangan dibuka; vendor sah mengirim PDF
Nominal tidak cocok PO	Cocokkan ke PO di sistem, bukan ke lampiran
Permintaan "tanda tangan dan kirim balik"	Approval pembayaran lewat alur internal, bukan email
Domain vendor mirip tapi bukan	Cek daftar vendor di sistem

---

5. Infrastruktur minimal (atau nol infrastruktur)

Opsi A — tanpa server (disarankan untuk mulai): Kirim email simulasi yang meminta staf **membalas "LAPOR"** bila mencurigakan. Yang diukur adalah *report rate* dan *click-by-reply*, tanpa halaman palsu, tanpa data apa pun yang terbentuk.

Opsi B — halaman statis: - Satu halaman HTML statis di hosting internal (bukan domain publik). - Hanya mencatat `recipient_id` + timestamp kedatangan. - **Tanpa** `<input type="password">`, tanpa form POST. - Tidak ada JavaScript yang membaca isi halaman. - Halaman langsung menampilkan: "*Ini latihan. Tidak ada data yang dikirim. Kembali ke pekerjaan Anda.*"

Opsi C — platform pihak ketiga: boleh, asalkan (a) data tinggal di wilayah yang disetujui, (b) kontrak menghapus data ≤ 90 hari, (c) tanpa simulasi yang meminta kata sandi.

---

6. Jadwal 6 minggu

Minggu	Aktivitas	Keluaran
1	Baseline: `booking_palsu`	CSV gelombang 1
2	Baseline: `payment_failed`	CSV gelombang 1b
3	Sesi 30 menit: 6 ciri pesan asli + 1 latihan berkelompok	daftar hadir, bukan nilai
4	Retest: `invoice_vendor`	CSV gelombang 2
5	Coaching 15 menit untuk yang klik (sukarela, tanpa catatan disiplin)	catatan coaching
6	Laporan agregat + keputusan: ulangi / naikkan level	laporan 1 halaman

Gelombang berikutnya **tidak** memakai template yang sama. Kalau template diulang, angka membaik karena hafalan, bukan karena kewaspadaan.

---

7. Ambang & putusan

Metrik	Ambang	Alasan angka ini
Kredensial terkirim	**0**	Satu saja = kegagalan kritis, apa pun angka lainnya
Klik	**≤ 10%**	Di atas itu, kontrol proses (approval, verifikasi) yang menahan, bukan orang
Lapor	**≥ 50%**	Lapor adalah perilaku yang ingin dibentuk, bukan menghindari klik
Kohort terkirim	**≥ 5**	Di bawah 5, angka tidak bisa disimpulkan (lihat §12)

Skrip menerjemahkan ini jadi exit code supaya bisa dipakai di CI/laporan otomatis:

Exit	Arti
`0`	Ambang terpenuhi
`2`	Ambang dilanggar (detail di stderr)
`3`	Data tidak cukup — **bukan** lulus
`1`	Berkas ditolak (kolom hilang, flag bukan 0/1, ID duplikat)

---

8. Checklist hari-H

1. [ ] Consent owner tertulis (tanggal, nama, cakupan) tersimpan.
2. [ ] Manager tahu jam kirim dan punya nomor kill switch.
3. [ ] Daftar penerima final (staf aktif, bukan tamu, bukan vendor).
4. [ ] Domain `.invalid` + `X-Drill: true` terpasang.
5. [ ] Tidak ada kolom sensitif di halaman (kalau Opsi B).
6. [ ] Kotak `security@` siap menerima laporan; ada yang memantau.
7. [ ] Tidak ada kampanye lain/insiden nyata di hari yang sama.
8. [ ] CSV kosong berheader sudah disiapkan untuk pengisian.

---

9. Pasca-latihan

Langkah	Aturan
Umpan balik	Kirim ke **semua** penerima dalam 24 jam: "Itu latihan. Ini 6 ciri yang bisa dipakai."
Coaching	Hanya untuk yang klik; 15 menit; fokus pada *apa yang membuat ragu*, bukan kesalahan
Laporan	Agregat per template; nama hanya di lampiran terpisah untuk manager langsung
Retensi	Data mentah dihapus ≤ 90 hari; simpan agregat + tanggal
Keputusan	Lulus → ulangi 6 bulan lagi dengan template baru. Gagal → perbaiki **proses** dulu (approval, verifikasi dua orang), lalu ulangi

---

10. Format CSV

Satu baris per penerima per gelombang. Semua flag **wajib** `0` atau `1` — nilai lain membuat berkas ditolak (gagal tertutup), bukan dianggap `0`.

```
recipient_id,template,delivered,clicked,submitted_credentials,reported
staff-01,booking_palsu,1,0,0,1
staff-02,booking_palsu,1,1,0,0
staff-03,payment_failed,1,0,0,1
```

Aturan validasi:

- `recipient_id` unik (duplikat = ditolak, karena bisa menggelembungkan penyebut).
- `clicked=1` mustahil tanpa `delivered=1`.
- `submitted_credentials=1` mustahil tanpa `clicked=1`.
- `reported=1` hanya untuk pesan yang terkirim.

`recipient_id` sebaiknya pseudonim (`staff-01`), bukan nama. Petakan ke nama di berkas terpisah yang dihapus setelah coaching.

---

11. Menjalankan skrip

```
/usr/bin/python3 scripts/phishing_drill_score.py data/drill_2026-11.csv
```

Contoh keluaran:

```
template                 terkirim   klik   klik%  kredensial  lapor%
-----------------------------------------------------------------
booking_palsu                   6      1   16.7%           0   66.7%
-----------------------------------------------------------------
TOTAL                           6      1   16.7%           0   66.7%
- booking_palsu: klik 16.7% melebihi batas 10%
PUTUSAN: AMBANG DILANGGAR
```

Skrip ini **tidak** mengirim email, tidak menyimpan data, dan tidak butuh jaringan.

---

12. Yang belum dicakup (jujur)

- **Vishing & WhatsApp** — kanal paling sering dipakai untuk menipu villa; butuh skrip terpisah.
- **Spear-phishing yang sangat personal** (nama anak, jadwal liburan) — sulit dibuat etis dan sulit diukur ulang.
- **Deepfake suara/video** — belum ada kontrol yang terbukti; jangan klaim terlindungi.
- **Kerentanan teknis** (SPF/DKIM/DMARC, kebocoran kredensial) diukur terpisah di §2, bukan di sini.
- **Angka ambang 10%/50%** adalah titik mulai yang wajar untuk tim kecil, **bukan** hasil penelitian. Setelah 2 gelombang, ganti dengan baseline tim sendiri — itulah angka yang bermakna.

13. Sisi tamu: satu pesan resmi untuk pelapor

Kalau tamu melaporkan pesan mencurigakan, balas dengan kalimat pendek ini (tanpa angka yang diketik, sesuai aturan template):

> Terima kasih telah memberi tahu kami. Kami tidak pernah meminta data kartu atau kata sandi lewat email atau chat, dan pembayaran hanya ke rekening yang tercantum di invoice resmi Anda. Mohon jangan membalas pesan tersebut; tim kami akan menghubungi Anda melalui kanal yang tertera di pesanan Anda.

Simpan salinan pesan yang dilaporkan (header lengkap) — itu bukti untuk blokir domain pengirim.